9.1.8 Lesson Review

Date: 4/5/2026, 2:37:11 PM

Time Spent: 02:34

Score: 100%

Passing Score: 80%

Question 1

Correct

What poses a greater threat than zero-day vulnerabilities?

- Newly released software
- Unpatched or legacy systems ✓ Correct
- Strong password policies
- Encrypted data storage

Explanation

Unpatched or legacy systems represent a significant security risk because they contain known vulnerabilities that have not been remediated. These systems are more common and can be exploited by a wider range of attackers compared to the relatively rare and sophisticated zero-day exploits.

While newly released software can contain vulnerabilities, it does not inherently pose a greater threat than zero-day vulnerabilities. Developers often patch known issues quickly after release.

Strong password policies are a security measure designed to protect against unauthorized access, not a threat.

Encrypted data storage is a security best practice that protects data confidentiality, making it an asset rather than a threat to security.

Related Content

9.1.1 Common Security Terminology

9.1.5 Vulnerability and Exploit Types

resources\questions\q_vuln_types_unpatched_legacy_threats_n09.question.xml

Question 2 Correct

What can the most serious vulnerabilities allow an attacker to do?

- ○ Increase system performance
- ◉ Execute arbitrary code on the system ✓ Correct
- ○ Improve application security
- ○ Encrypt system files for data protection

Explanation

The most serious vulnerabilities can allow attackers to execute arbitrary code, which means they can run any commands or install any software they choose on the victim's system. This level of control can lead to data theft, system damage, or further exploitation.

Exploiting vulnerabilities typically leads to negative outcomes, such as unauthorized access or system damage, rather than beneficial effects like increased system performance.

Exploiting a vulnerability compromises application security rather than improving it. The goal of an attacker is to bypass security measures, not enhance them.

While encryption is a method of protecting data, attackers exploiting vulnerabilities are more likely to encrypt files as part of a ransomware attack, not for the purpose of protecting the victim's data.

Related Content

- 9.1.1 Common Security Terminology
- 9.1.5 Vulnerability and Exploit Types

resources\questions\q_vuln_types_arbitrary_code_n09.question.xml

Question 3 Correct

What does "integrity" in the context of the CIA Triad mean?

- (selected) The data is stored and transferred as intended and that any modification is authorized. ✓ Correct
- Information is accessible to those authorized to view or modify it.
- Certain information should only be known to certain people.
- The system is protected against unauthorized access and attacks.

Explanation

The correct answer is that data is stored and transferred as intended and that any modification is authorized. Integrity ensures that data remains accurate and consistent during its lifecycle. This means that unauthorized changes to the data, whether in storage, processing, or transit, are prevented or detected.

Information is accessible to those authorized to view or modify it describes "availability," which is about ensuring authorized users have access to information and resources.

Certain information should only be known to certain people describes "confidentiality," which is about ensuring that information is only accessible to those who are authorized.

The system is protected against unauthorized access and attacks is a broader security goal, not specifically related to the "integrity" aspect of the CIA Triad.

Related Content

9.1.1 Common Security Terminology

resources\questions\q_sec_concepts_integrity_n09.question.xml

Question 4 Correct

What does "availability" in the CIA Triad refer to?

- The data is stored and transferred as intended and that any modification is authorized.
- Information and resources are accessible to those authorized when needed. ✓ Correct
- Information is protected from unauthorized access except to those with the proper permissions.
- The system is protected against unauthorized access, attacks, and disclosure.

Explanation

Availability ensures that data, systems, and services are available to authorized users when needed. This involves protecting against attacks that can lead to unauthorized denial of service, ensuring system uptime, and providing reliable access to resources.

The data being stored and transferred as intended and that any modification is authorized describes "integrity," which is about ensuring data remains unchanged unless the change is authorized.

Information being accessible only by authorized individuals describes "confidentiality," which is about restricting access to information to those authorized to view or modify it.

The system being protected against unauthorized access and attacks describes "confidentiality", rather than the "availability" aspect of the CIA Triad.

Related Content

9.1.1 Common Security Terminology

resources\questions\q_sec_concepts_availability_n09.question.xml

Question 5 Correct

What is the difficulty in implementing security controls?

- They are always too complex to implement.
- They can be expensive. ✓ Correct
- They are not supported by IT service frameworks.
- They only address low-level risks.

Explanation

While security controls are essential for mitigating risks, they can be expensive. Organizations must balance the cost of implementing these controls against the potential cost of the risks they mitigate.

Complexity can be a factor, but the main difficulty is often the cost.

IT service frameworks actually support and guide the implementation of security controls.

Security controls address a wide range of risks, not just low-level ones.

Related Content

resources\questions\q_sec_assess_security_control_difficulty_n09.question.xml

Question 6 Correct

What does a risk assessment involve?

- ○ Auditing the company's financial statements for fraud
- ◉ Auditing the company's systems for risk factors ✓ Correct
- ○ Conducting physical security checks on company premises
- ○ Reviewing employee performance and productivity

Explanation

Risk assessment is a subset of risk management where the company's systems and procedures are audited for risk factors. It involves identifying and evaluating the risks to the organization's information assets.

Auditing financial statements for fraud is related to financial audit, not risk assessment in the context of cybersecurity.

Physical security checks are part of overall security but not specifically what risk assessment entails.

Reviewing employee performance is unrelated to the process of identifying and evaluating cybersecurity risks.

Related Content

- 9.1.1 Common Security Terminology
- 9.1.2 Security Audits and Assessments
- 9.1.3 Regulatory Compliance
- 9.1.5 Vulnerability and Exploit Types

resources\questions\q_sec_assess_risk_assessment_n09.question.xml

Question 7 Correct

What is the purpose of a cybersecurity audit?

- To assess the organization's IT budget
- To ensure a security posture aligns with established standards ✓ Correct
- To train employees on cybersecurity best practices
- To install security software on all company devices

Explanation

Cybersecurity audits are comprehensive reviews designed to ensure that an organization's security measures are in line with established standards and best practices. They assess various aspects of the organization's security posture.

Assessing the IT budget is not the purpose of a cybersecurity audit.

Training employees on cybersecurity best practices is important but not the purpose of a cybersecurity audit.

Installing security software is a security measure but not the purpose of conducting an audit.

Related Content

- 9.1.1 Common Security Terminology
- 9.1.2 Security Audits and Assessments
- 9.1.3 Regulatory Compliance
- 9.1.5 Vulnerability and Exploit Types

resources\questions\q_sec_assess_cybersecurity_audit_n09.question.xml

Question 8 Correct

What is Personally Identifiable Information (PII)?

- Any data that can be publicly accessed
- Data that can identify, contact, or locate an individual ✓ Correct
- Information related to a company's financial status
- Data that is encrypted and stored securely

Explanation

PII includes any data that can be used on its own or with other information to identify, contact, locate, or describe a single person. Examples include Social Security Numbers, names, addresses, email addresses, and biometric data.

PII is specifically about data that can identify individuals, not publicly accessible data.

Information related to a company's financial status is not considered PII as it does not identify individuals.

Whether data is encrypted and stored securely is irrelevant to its classification as PII; it's about the nature of the data itself.

Related Content

9.1.3 Regulatory Compliance

resources\questions\q_reg_comp_pii_role_n09.question.xml

Question 9 Correct

Under what condition can an organization process credit card transactions directly?

- If they use cloud storage
- If they have an internet presence
- If they adopt the PCI DSS standard ✓ Correct
- If they encrypt all their emails

Explanation

Organizations that directly process credit card transactions must comply with the PCI DSS standard to ensure the security of the cardholder data environment. Adoption of these standards is mandatory for processing transactions.

Using cloud storage does not directly relate to the ability to process credit card transactions.

Having an internet presence is common for businesses but does not qualify them to process credit card transactions without PCI DSS compliance.

Encrypting emails is a good security practice but does not fulfill the requirements for directly processing credit card transactions.

Related Content

9.1.3 Regulatory Compliance

resources\questions\q_reg_comp_direct_transactions_n09.question.xml

Question 10 Correct

What does data locality require?

- ○ Data to be stored in the cloud
- ○ Data to be encrypted at all times
- ◉ Data storage within certain geographical boundaries ✓ Correct
- ○ Unlimited data transfer between countries

Explanation

Data locality involves establishing policies and tools that ensure data is stored and processed within specific national or state borders. This is often required to comply with data sovereignty laws and protect data privacy.

Cloud storage is a method of storing data, but data locality focuses on the geographical location of the data.

Encryption is a security measure, not a requirement of data locality, which focuses on geographical boundaries.

Data locality actually imposes restrictions on data transfer between countries, contrary to allowing unlimited transfers.

Related Content

9.1.3 Regulatory Compliance

resources\questions\q_reg_comp_data_locality_requirement_n09.question.xml

Question 11 Correct

What is meant by "data at rest"?

- ○ Data being transmitted over a network
- ◉ Data stored on a persistent storage media ✓ Correct
- ○ Data present in volatile memory
- ○ Data being actively processed by a computer

Explanation

Data at rest refers to data that is stored on any form of persistent storage media, such as hard drives, SSDs, or cloud storage. It is not being actively transmitted or processed, making it susceptible to different security threats than data in transit or in use.

Data being transmitted over a network is considered data in transit.

Data present in volatile memory is considered data in use.

Data being actively processed is also considered data in use, not data at rest.

Related Content

- 1.3.5 Transport and Application Layer and Security Functions
- 5.2.5 Border Gateway Protocol
- 6.1.2 Transmission Control Protocol
- 9.1.4 Encryption
- 9.5.2 Password Attacks
- 10.1.5 Digital Certificates and PKI

resources\questions\q_encryption_data_at_rest_n09.question.xml

Question 12 Correct

What does a ciphertext represent in the context of encryption?

- ○ The original human-readable information
- ◉ The encrypted version of plaintext ✓ Correct
- ○ The key used to encrypt the plaintext
- ○ The conversion of plaintext into a hash

Explanation

Ciphertext is the result of the encryption process, where plaintext (human-readable information) is converted into an encrypted, unreadable format. This ensures confidentiality, as the ciphertext can only be decrypted back into plaintext by those who possess the correct decryption key.

The original human-readable information is referred to as plaintext, not ciphertext.

The key is a separate entity used in the encryption and decryption processes, not the ciphertext itself.

Converting plaintext into a hash is a different process, related to cryptographic hashing, not encryption.

Related Content

- 1.3.5 Transport and Application Layer and Security Functions
- 5.2.5 Border Gateway Protocol
- 6.1.2 Transmission Control Protocol
- 9.1.4 Encryption
- 9.5.2 Password Attacks
- 10.1.5 Digital Certificates and PKI

resources\questions\q_encryption_cyphertext_n09.question.xml

Question 13 Correct

What is the role of encryption in an access control solution?

- To physically secure devices and resources
- To serve as the only method of access control
- To convert plaintext into ciphertext ✓ Correct
- To give readable access to data

Explanation

Encryption is a logical security system that converts human-readable plaintext into unreadable ciphertext. This process ensures data confidentiality, as the ciphertext can only be decrypted and read by those who possess the correct key.

Encryption is a form of logical security, not physical security.

Encryption is one of many methods used in access control solutions, not the sole method.

Encryption restricts access to data by making it unreadable without the correct decryption key.

Related Content

- 1.3.5 Transport and Application Layer and Security Functions
- 5.2.5 Border Gateway Protocol
- 6.1.2 Transmission Control Protocol
- 9.1.4 Encryption
- 9.5.2 Password Attacks
- 10.1.5 Digital Certificates and PKI

resources\questions\q_encryption_acs_encryption_n09.question.xml

Question 14 Correct

What is a honeypot in the context of cybersecurity?

- ○ A type of malware designed to steal data
- ◉ A computer system set up to attract attackers ✓ Correct
- ○ A software tool used for encrypting data
- ○ A firewall configuration technique

Explanation

A honeypot is deliberately designed to appear vulnerable and attractive to attackers. Its purpose is to lure cybercriminals so that their behavior can be studied, which helps in understanding attack strategies and tools. This information can be used to improve security measures and provide early warning of attack attempts.

A honeypot is not malware but a security mechanism designed to trap attackers.

It is not a tool for encrypting data but rather a decoy for monitoring and analyzing attacks.

It is not related to firewall configurations but is a separate entity designed to mimic real systems to attract attackers.

Related Content

9.1.6 Deception Technologies

9.1.7 Lab: Create a Honeypot

resources\questions\q_deception_honeypot_n09.question.xml

Question 15 Correct

What is one of the key benefits of using a honeypot or honeynet in cybersecurity?

- ○ Completely eliminating cyber threats
- ◉ Providing an early warning of attacks ✓ Correct
- ○ Increasing the encryption strength
- ○ Reducing the need for other security measures

Explanation

Honeypots and honeynets are designed to mimic real systems and networks to attract attackers, allowing security teams to monitor and analyze unauthorized activities. One of the key benefits of this approach is providing an early warning of attack attempts. By detecting and analyzing these attempts in their early stages, organizations can respond more effectively to mitigate potential threats before they impact critical systems or data.

While honeypots and honeynets are valuable tools in a cybersecurity strategy, they do not completely eliminate cyber threats. They are part of a broader security approach that includes various tools and practices to protect against a wide range of cyber risks.

Honeypots and honeynets do not directly affect encryption strength. Encryption is a method of securing data by converting it into a code to prevent unauthorized access, while honeypots and honeynets are decoy systems used for monitoring and analyzing attacks.

Using honeypots and honeynets does not reduce the need for other security measures. Instead, they complement existing security practices by adding an additional layer of defense. Organizations still need to implement a comprehensive security strategy that includes firewalls, antivirus software, encryption, and other measures to protect against various cyber threats.

Related Content

resources\questions\q_deception_early_warning_n09.question.xml

Copyright © CompTIA, Inc. All rights reserved.